

File Upload

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- El formulario solo comprueba la extensión del NOMBRE, no el contenido real del fichero.
- Puedes predecir o descubrir la ruta donde se guardan los uploads (uploads/, /files/, patron de nombre).

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>curl -sS -F 'file=@shell.phtml;type=image/png' "\$URL/upload"</code>	Sube un fichero .phtml (extensión alternativa que muchos servidores PHP también ejecutan) declarando un Content-Type de imagen para intentar pasar validaciones basadas en ese campo.	La respuesta suele indicar éxito y a veces la ruta del fichero subido. Si no la da, prueba rutas predecibles (uploads/shell.phtml) o busca un listado de directorio.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.